

DATA BREACH NOTIFICATION AND INCIDENT RESPONSE STANDARDS, 2026 (ILLUSTRATIVE)

Sample document generated for RAG test-dataset purposes — not an official publication

1. Scope

1.1 These Standards apply to any entity processing personal data of more than 10,000 individuals, including data processors acting on behalf of such entities.

2. Breach Classification

2.1 A breach affecting fewer than 500 individuals with no sensitive personal data involved is classified as Low Severity. 2.2 A breach involving financial credentials, health data, or more than 10,000 individuals is classified as Critical Severity.

3. Notification Timelines

3.1 A Critical Severity breach must be reported to the Data Protection Authority within 6 hours of detection. 3.2 A Moderate or Low Severity breach must be reported within 72 hours of detection. 3.3 Affected individuals must be notified within 7 days for Critical Severity breaches unless law enforcement requests a delay for investigation.

4. Mandatory Report Contents

4.1 A breach report must include the nature of the breach, categories and approximate number of individuals affected, likely consequences, and measures taken or proposed to address the breach. 4.2 A follow-up report with root-cause analysis must be filed within 30 days of the initial notification.

5. Remediation Obligations

5.1 An entity must offer free credit monitoring for 12 months to affected individuals in any Critical Severity breach involving financial data. 5.2 Failure to patch a known vulnerability within 15 days of a vendor security advisory, where that vulnerability leads to a breach, shall be treated as an aggravating factor in penalty determination.

6. Penalties

6.1 Failure to notify within the timeline under Section 3.1 shall attract a penalty of up to Rs. 5 crore or 2% of global annual turnover, whichever is higher. 6.2 Repeated non-compliance within a 3-year period shall attract twice the penalty amount for each subsequent violation.